ONE-PAGE BRIEF

Post-quantum cryptography review: stellar-core @ 362dbc5184c5

Client: Stellar Development Foundation — public repository (passive review) · Source: github.com/stellar/stellar-core, commit `362dbc5184c5` · Reviewed: 2026-11-06 16:13 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 1 of 4
post-quantum code present, not wired

FINDINGS
0 Critical **3** High **24** Medium
18 Low **5** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Wire the existing post-quantum primitive into a critical path (key wrapping or the channel) behind a hybrid construction, and test interoperability.

WHAT MATTERS MOST

High	QSI-2026-19575	**Possible hard-coded secret in lib/sqlite/sqlite3.c** preliminary What to do: Move secrets to a secrets manager/environment; rotate the exposed values.
High	QSI-2026-19582	**Possible hard-coded secret in lib/tracy/nfd/nfd_portal.cpp** preliminary What to do: Move secrets to a secrets manager/environment; rotate the exposed values.
High	QSI-2026-19587	**Non-cryptographic generator next to key or seed generation in src/crypto/SecretKey.h** preliminary What to do: Use the platform CSPRNG (secrets, os.urandom, crypto.getRandomValues, crypto/rand, SecureRandom, OsRng) or a hardware TRNG for every key...
Medium	QSI-2026-19595	**stellar-xdr 21.2.0 is affected by GHSA-x57h-xx53-v53w (CVE-2026-29795)** What to do: Upgrade to a fixed version (25.0.1).

41 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium key wrapping and data encryption at rest	X25519	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may...
Medium transaction and message signing	Ed25519, ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	Ed25519	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	Ed25519, ECDSA, BLS12-381, X25519	Classify each usage, record data lifetimes, and plan migration to Hybrid key establishment with ML-KEM (FIPS...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 32; unlikely to apply to this build: 2 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 30.

Static review of source code and manifests; files analysed: 3388. No requests were sent to the owner's systems.

Full report, content SHA-256: `f327ba1b869fa8b4294a76c06b8c8cab443e20fce8fcaa92ea2b8a6bee57463e`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.